

ENTERPRISE ARCHITECTURE

Interview Handbook

Δ DELTA EDITION

Emerging Topics · Industry-Current Concerns · Unexplored Architecture Domains

Post-Quantum Cryptography · EU AI Act Compliance · AI FinOps · Composable Architecture
Supply Chain Security · Sustainable Architecture · DORA Compliance · Autonomous Operations
Responsible AI · Edge Computing · Integration Modernisation · Architecture Leadership 2026

Supplement to: EA Interview Handbook (Distinguished Architect Edition)
Targeting: Microsoft · Google · Amazon · JPMorgan · Goldman Sachs · Barclays · Visa · ServiceNow

ABOUT THIS DELTA EDITION

This Delta Edition supplements the EA Interview Handbook with 12 new sections covering topics not addressed in the original volume. Every section addresses a current industry concern verified against 2025-2026 analyst research, regulatory developments, and real deployment patterns at organisations including JPMorgan, HSBC, Barclays, Microsoft, and Google.

What is NEW in this edition:

ID	Section	Industry Signal
D1	Post-Quantum Cryptography	NIST mandates PQC migration. HNDL threat is live today. 2028-2031 CRQC window.
D2	EU AI Act Compliance	High-risk AI enforcement August 2026. Fines up to 6% global turnover.
D3	AI FinOps	98% of FinOps teams now manage AI spend. Token costs are the new cloud bill.
D4	Composable Architecture & Digital Twins	Gartner: composable architecture competitive differentiator by 2026.
D5	Supply Chain Security	SBOM, DORA ICT vendor risk, model supply chain — fastest-growing attack vector.
D6	Sustainable Architecture	CSRD mandates technology carbon reporting from 2025.
D7	Enterprise Integration Modernisation	10,000-integration estates blocking AI adoption. API economy architecture.
D8	DORA Compliance Architecture	Most prescriptive technology regulation in EU financial services history.
D9	Autonomous Operations & AIOps	AI agents managing infrastructure — architecture with no established playbook.
D10	Responsible AI Architecture	Explainability, fairness monitoring, and bias detection as operational metrics.
D11	Edge Computing	75% of enterprise data generated at the edge by 2026.
D12	Architecture Leadership 2026	The Augmented Architect: AI fluency + business acumen + behavioural science.

TABLE OF CONTENTS — DELTA EDITION

D1 — Post-Quantum Cryptography Migration

- PQC Standards
- Crypto-Agile Architecture
- Migration Roadmap
- PKI Modernisation

● **INDUSTRY SIGNAL: CRITICAL** — NIST mandates quantum-resistant algorithms by 2026. Financial services face exi...

D2 — EU AI Act Architecture Compliance

- Risk Classification
- Conformity Assessment Architecture
- Technical Documentation
- Human Oversight Design

● **INDUSTRY SIGNAL: LIVE** — EU AI Act high-risk system requirements enforcement begins August 2026. Fines up to...

D3 — AI FinOps — Governing AI Cost at Scale

- AI Cost Governance
- Token Economics
- FinOps for Agents
- Unit Economics

● **INDUSTRY SIGNAL: IDC** warns G1000 organisations face 30%+ underestimated AI infrastructure costs by 2027. 98...

D4 — Composable Architecture & Digital Twins

- Composable Business
- Packaged Business Capabilities
- Digital Twin of Organisation
- MACH Architecture

● **INDUSTRY SIGNAL: Gartner:** composable architecture will be a competitive differentiator by 2026. Digital Twi...

D5 — Technology Supply Chain Security

- SBOM Architecture
- Third-Party Risk
- Open Source Governance
- Model Supply Chain

● **INDUSTRY SIGNAL:** Supply chain attacks are the #1 fastest-growing attack vector. DORA requires ICT third-par...

D6 — Sustainable Architecture & Green IT

- Carbon-Aware Architecture
- Green Cloud Strategy
- CSRD Technology Reporting
- Sustainable AI

● **INDUSTRY SIGNAL: CSRD (Corporate Sustainability Reporting Directive)** mandates technology carbon reporting f...

D7 — Enterprise Integration Modernisation

- API Economy
- Event-Driven Architecture
- Integration Modernisation
- AsyncAPI / CloudEvents

● **INDUSTRY SIGNAL:** Legacy integration debt is blocking AI adoption. 10,000-integration estates are common. Ev...

D8 — Resilience Engineering & DORA Compliance

- DORA Architecture Requirements
- Resilience Testing
- ICT Incident Classification
- Critical Functions

● **INDUSTRY SIGNAL:** DORA (EU Digital Operational Resilience Act) is in force for EU financial institutions in ...

D9 — Autonomous Operations & AIOps

- Autonomous Operations Platform
- AIOps Architecture
- Self-Healing Systems
- Human Override Governance

● **INDUSTRY SIGNAL:** By 2026, G2000 companies will deploy thousands of AI agents. AIOps is moving from anomaly ...

D10 — Architecture for AI Regulation & Responsible AI

- Responsible AI Framework
- Explainability Architecture
- Fairness Monitoring
- AI Incident Response

● **INDUSTRY SIGNAL:** 92% of EA leaders cite AI and agentic architecture as their top 2026 priority. Responsible...

D11 — Edge Computing & Distributed Architecture

- Edge Architecture Patterns
- Edge AI
- 5G Enterprise Architecture
- Edge Security

● **INDUSTRY SIGNAL:** By 2026, edge computing handles 75% of enterprise-generated data. 5G, IoT, and AI inferenc...

D12 — Architecture Leadership & The Augmented Architect

- EA Value Proposition 2026
- AI-Augmented Architecture Practice
- Architecture as Consultancy
- Skills for Distinguished Architects

● **INDUSTRY SIGNAL:** Forrester's 'Augmented Architect' (2025): architects who combine AI fluency with business ...

SECTION D1

POST-QUANTUM CRYPTOGRAPHY MIGRATION

■ **INDUSTRY SIGNAL: CRITICAL** — NIST mandates quantum-resistant algorithms by 2026. Financial services face existential 'Harvest Now, Decrypt Later' (HNDL) risk. CRQC estimated by 2028-2031.

[PQC Standards] [Crypto-Agile Architecture] [Migration Roadmap] [PKI Modernisation]

Q1 **DISTINGUISHED** [PQC] [NIST] [Crypto-Agility] [Banking]

Design an enterprise post-quantum cryptography migration programme for a global bank. How do you approach crypto-agility as an architectural principle?

HINTS

- HNDL threat model
- ML-KEM / ML-DSA NIST standards
- Cryptographic inventory
- Hybrid transition patterns

MODEL ANSWER

The threat is immediate even before quantum computers exist. 'Harvest Now, Decrypt Later' means adversaries are archiving today's encrypted traffic — your SWIFT messages, customer records, trading communications — to decrypt when a Cryptographically Relevant Quantum Computer (CRQC) arrives (estimated 2028-2031).

Phase 0 — Cryptographic Inventory (Months 1-3):

- Discover every cryptographic asset: TLS certificates, JWT signing keys, HSM key material, SSH keys, code-signing certificates, S/MIME certificates, database encryption keys
- Classify by quantum vulnerability: RSA, ECDSA, ECDH, DHE are all quantum-vulnerable. AES-256 and SHA-3 are quantum-resistant.
- Prioritise by data sensitivity and retention period: data with 10+ year value needs immediate protection

Phase 1 — Hybrid Transition (Months 3-18):

- Adopt hybrid TLS: ML-KEM + X25519 for key exchange (AWS, Cloudflare, Akamai already deploying this)
- Adopt hybrid signatures: ML-DSA + ECDSA for JWT tokens, SAML assertions, X.509 certificates
- Update HSMS: verify ML-KEM and ML-DSA support — not all HSMS are PQC-ready. Prioritise HSM upgrade cycle.
- Update PKI: migrate root CA and intermediate CAs to hybrid certificates on next renewal cycle

Phase 2 — Full PQC (Months 18-36):

- Retire classical-only algorithms from all production systems
- SWIFT and interbank messaging: coordinate PQC migration with counterparty banks — cannot migrate independently
- Payment card cryptography (PCI-DSS): coordinate with card schemes (Visa/Mastercard PQC migration programmes)

Crypto-Agile Architecture:

- Cryptographic Algorithm Registry: every system declares its cryptographic dependencies as configuration, not hardcode
- Algorithm abstraction layer: applications call 'sign(data)' not 'ECDSA-sign(data)' — algorithm is injected at runtime
- Certificate lifecycle management: automated rotation with PQC support in CA platform

- Crypto fitness function: CI/CD pipeline scans for hardcoded quantum-vulnerable algorithms and fails build

FOLLOW-UP CHALLENGE

A regulator asks for your PQC migration roadmap and evidence that your HNDL risk is being addressed. What do you present?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 CHIEF ARCHITECT [PQC] [PKI] [Identity]

How does post-quantum migration affect your identity architecture — specifically JWT tokens, SAML assertions, and X.509 certificates?

HINTS

- ML-DSA replaces ECDSA/RSA signatures
- Token verification libraries
- Federation trust chains
- FIDO2/passkey quantum implications

MODEL ANSWER

Every digital signature in your identity stack is quantum-vulnerable today.

JWT Tokens:

- RS256/ES256 (RSA/ECDSA signatures) are quantum-vulnerable — a CRQC can forge tokens
- Migration path: adopt ML-DSA-65 for JWT signing. Requires: updated signing library in token service, updated verification logic in all resource servers, and a transition period where both algorithms are accepted
- Short token TTL (15 minutes) provides defence-in-depth: even if tokens are forged, the window is narrow

SAML Assertions:

- SAML XML signatures use RSA or ECDSA — both quantum-vulnerable
- Migration: update IdP signing certificate to ML-DSA hybrid; SP metadata must be updated to trust new certificate
- SAML federation with external partners (B2B) requires coordinated certificate rotation — cannot do unilaterally

X.509 Certificates:

- Plan: migrate public-facing TLS to hybrid ML-KEM + X25519 on next certificate renewal
- Internal PKI: migrate intermediate CA on next planned rotation; leaf certificates follow automatically
- Client certificates (mTLS for service mesh): update SPIFFE/SPIRE CA to issue ML-DSA SVIDs

FIDO2/Passkeys:

- Current FIDO2 uses ECDSA P-256 — quantum-vulnerable for stored credentials
- FIDO Alliance has PQC working group targeting ML-DSA integration. Plan for credential re-registration cycle.

Governance: build a crypto migration dashboard tracking % of tokens, certificates, and assertions migrated to PQC. Report quarterly to CISO.

FOLLOW-UP CHALLENGE

Your largest enterprise customer uses a 10-year-old SAML SP that cannot support hybrid certificates. How do you handle this exception?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D2

EU AI ACT ARCHITECTURE COMPLIANCE

■ **INDUSTRY SIGNAL: LIVE** — EU AI Act high-risk system requirements enforcement begins August 2026. Fines up to €30M or 6% global turnover. 78% of organisations use AI; most lack compliant governance architecture.

[Risk Classification] [Conformity Assessment Architecture] [Technical Documentation] [Human Oversight Design]

Q1 **DISTINGUISHED** [EU AI Act] [Compliance Architecture] [High-Risk AI]

Design an architecture that makes your enterprise AI systems EU AI Act compliant for high-risk use cases — credit decisioning, fraud detection, and HR screening.

HINTS

- Risk classification tiers
- Annex IV technical documentation
- Human oversight requirements
- Conformity assessment
- GPAI obligations

MODEL ANSWER

The EU AI Act classifies AI by risk tier. High-risk systems (credit, fraud, HR) face the heaviest obligations. Non-compliance: up to €30M or 6% of global turnover.

Architecture for High-Risk AI Compliance:

1. Risk Classification Engine:

- Every AI system registered in the AI system registry with: use case, data inputs, decision type, affected population
- Automated classification tool maps each system to EU AI Act Annex III categories
- High-risk flag triggers mandatory compliance workflow before production deployment

2. Technical Documentation (Annex IV compliance):

- General system description: purpose, intended users, deployment context
- Detailed description of elements and development process: training data, model architecture, performance metrics
- Monitoring, functioning, and control measures: how the system is monitored post-deployment
- Risk management documentation: all identified risks and mitigation measures
- Changes over lifecycle: version control for model and documentation
- Store in immutable, versioned documentation platform (Git-backed, WORM-archived)

3. Data Governance for AI Act:

- Training data documentation: provenance, representative coverage, bias assessment, data minimisation evidence
- Prohibited data use: EU AI Act prohibits use of sensitive categories (race, religion, sexual orientation) for inference — enforce at data pipeline level
- Ongoing data quality monitoring: drift detection on input distribution

4. Human Oversight Architecture:

- For credit and HR decisions: human review of every AI recommendation before consequential action
- Override capability: humans can always override AI decision — logged with reasoning

- Explanation interface: every high-risk decision generates a human-readable explanation (SHAP/LIME + natural language summary)
- Operator training records: evidence that humans operating the system are trained on its limitations

5. Conformity Assessment:

- Self-assessment for most high-risk AI systems (third-party audit for biometrics/critical infrastructure)
- EU Database registration: mandatory registration in EU AI systems database before deployment
- Post-market monitoring: performance dashboards available to regulators on request

FOLLOW-UP CHALLENGE

The EU Commission classifies your fraud detection model as 'critical infrastructure AI' requiring third-party conformity assessment. Your model is a proprietary trade secret. How do you navigate this?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [EU AI Act] [GPAI] [Model Governance]

Your enterprise uses GPT-4 class models (General Purpose AI) in multiple products. What are your EU AI Act obligations as a GPAI deployer?

HINTS

- GPAI code of practice
- Systemic risk models
- Transparency obligations
- Downstream deployer responsibilities

MODEL ANSWER

GPAI (General Purpose AI) obligations took effect August 2025.

As a deployer (not the model provider):

- You are responsible for the deployment context and use case
- If you deploy a GPAI model in a high-risk application, your high-risk AI obligations apply to your system
- You cannot outsource compliance to the model provider — they cover their model; you cover your application

Transparency obligations for your deployments:

- Inform users when they are interacting with AI (chatbots, automated decisions)
- AI-generated content must be machine-readable labelled (C2PA watermarking standard)
- Do not deploy GPAI for prohibited uses (social scoring, real-time biometric surveillance in public)

Systemic risk (if your AI platform itself becomes GPAI-scale):

- GPAI models above 10^{25} FLOPs training compute face systemic risk obligations
- This currently applies to model providers (OpenAI, Anthropic, Google) not deployers
- BUT: if you fine-tune foundation models to build products you distribute, you may become a provider

Practical architecture controls:

- AI system inventory: every GPAI deployment tagged with: model version, provider, deployment purpose, user-facing flag

- Contract management: ensure model provider agreements include audit rights, security obligations, and incident notification
- Incident register: log all AI system incidents — required for regulatory reporting under EU AI Act Article 73

FOLLOW-UP CHALLENGE

Your enterprise builds a customer-facing AI assistant on top of a third-party GPAI model. The model produces a biased response that causes demonstrable harm to a customer. Who is liable under EU AI Act?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D3

AI FINOPS — GOVERNING AI COST AT SCALE

■ **INDUSTRY SIGNAL:** IDC warns G1000 organisations face 30%+ underestimated AI infrastructure costs by 2027. 98% of FinOps teams now manage AI spend (up from 63% in 2025). Token costs are the new compute costs.

[AI Cost Governance] [Token Economics] [FinOps for Agents] [Unit Economics]

Q1 **CHIEF ARCHITECT** [AI FinOps] [Cost Governance] [LLM Economics]

Design an AI FinOps framework for an enterprise running 500 AI applications consuming \$20M/year in LLM tokens. How do you govern cost without killing innovation?

HINTS

- Token budgets per team
- Cost attribution
- Semantic caching
- Model routing by cost tier
- Chargeback vs showback

MODEL ANSWER

AI cost is fundamentally different from cloud compute cost: it is unbounded by nature, highly variable, and directly correlated with quality of product experience. Traditional FinOps approaches (rightsizing, reserved instances) do not translate directly.

Architecture for AI FinOps:

1. Cost Visibility Layer (via AI Gateway):

- Every LLM call tagged: team, application, model, prompt tokens, completion tokens, cost
- Real-time cost dashboard per team: daily spend vs. budget, cost per user, cost per transaction
- Anomaly detection: alert when spend rate exceeds 2x rolling average

2. Token Budget Allocation:

- Annual token budget allocated per product team based on: user base, revenue contribution, strategic priority
- Monthly review cycle: teams forecasting over-budget must present optimisation plan
- Innovation budget: 10-15% of total AI spend ring-fenced for experimentation — no chargeback, no bureaucracy

3. Model Routing by Cost Tier:

- Tier 1 (cheap, fast): small models for classification, routing, summarisation (GPT-4o mini, Haiku)
- Tier 2 (mid): general reasoning, document processing (Sonnet, GPT-4o)
- Tier 3 (expensive): complex reasoning, code generation (Opus, o1, GPT-4)
- AI Gateway routes to cheapest model that meets the task's quality threshold

4. Semantic Caching:

- Cache identical and semantically similar prompts — reduces token spend 15-30% for repetitive workloads
- Cache invalidation: time-based + content change detection

5. Chargeback vs Showback:

- Year 1: Showback only — show teams their cost without charging. Builds awareness without adding friction.

- Year 2: Chargeback for teams above budget threshold. Creates accountability at product P&L; level.
- Never chargeback innovation budget — protect experimentation.

FOLLOW-UP CHALLENGE

Your agentic workflows run thousands of AI agent loops overnight. The next morning you discover a runaway agent consumed \$500K in tokens due to an infinite loop. Walk through your architectural response and prevention.

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [FinOps] [Agents] [Cost Control]

How do you apply FinOps principles specifically to AI agent systems where cost is emergent and unpredictable?

HINTS

- Agent token budgets
- Circuit breakers
- Cost-aware orchestration
- Spend-per-task limits

MODEL ANSWER

Traditional agent orchestration frameworks have no native cost governance. This is a critical architectural gap.

Cost dimensions unique to agents:

- Reasoning loops: agents that think before acting can consume 5-10x more tokens than single-shot inference
- Tool call chains: each tool call may trigger additional LLM calls (React pattern)
- Multi-agent: orchestrator + sub-agents multiply costs exponentially
- Context accumulation: agents carry growing context windows over long sessions

Architectural controls:

1. Per-task token budget: every agent task launched with a declared token budget. Agent tracks spend.
2. Spend circuit breaker: when task exceeds 80% of budget, agent enters 'frugal mode' — no further tool calls, use cached results only
3. At 100% budget: task suspended, human notified, not silently failed
4. Context pruning: implement context window management — summarise old turns rather than accumulating raw history
5. Model downgrade: if task is taking too long, route remaining steps to cheaper model
6. Cost estimation before execution: for high-cost task classes, estimate token cost before execution and require approval above threshold

Monitoring:

- Cost-per-agent-task metrics in observability stack
- Alert on tasks with cost > 3 sigma from baseline
- Daily digest to product owners: top 10 most expensive agent tasks yesterday

FOLLOW-UP CHALLENGE

Business wants to deploy 10,000 AI agents to automate back-office processes. Finance asks for a cost model. What do you build?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D4

COMPOSABLE ARCHITECTURE & DIGITAL TWINS

■ **INDUSTRY SIGNAL:** *Gartner: composable architecture will be a competitive differentiator by 2026. Digital Twin of the Organisation (DTO) is emerging as the EA management plane for real-time decision support.*

[Composable Business] [Packaged Business Capabilities] [Digital Twin of Organisation] [MACH Architecture]

Q1 **DISTINGUISHED** [Composable Architecture] [PBC] [MACH]

What is composable architecture and when does it create genuine competitive advantage versus adding unnecessary complexity?

HINTS

- Packaged Business Capabilities
- MACH principles
- Integration overhead
- Organisational composability

MODEL ANSWER

Composable architecture: systems assembled from interchangeable, independently deployable capabilities (Packaged Business Capabilities — PBCs) rather than built as integrated monoliths.

MACH principles: Microservices, API-first, Cloud-native, Headless. Each component is replaceable without rebuilding the whole.

Where composability creates genuine competitive advantage:

1. Rapid market response: A bank can launch a new product by composing existing PBCs (identity + credit scoring + account management + payments) in weeks rather than months
2. Best-of-breed selection: Replace underperforming components without wholesale platform replacement
3. Embedded finance: Composable banking APIs can be embedded in third-party products — BaaS model requires composability
4. AI integration: Plug AI models as interchangeable capabilities — swap models as the market evolves without re-architecting

Where composability adds complexity without proportionate value:

1. Small organisations: integration overhead exceeds benefit when you have fewer than 50 engineers
2. Stable domains: composability is not valuable for capabilities that never change
3. Latency-critical systems: each composition boundary adds network hops. Trading systems, real-time payments have hard latency budgets
4. Without organisational composability: if your teams are not composable (autonomous, stream-aligned), your architecture cannot be composable either

The honest test: before calling something composable, ask — 'Can we replace this component in isolation without coordinating with more than one other team?' If no, it is not actually composable.

FOLLOW-UP CHALLENGE

Your CTO says 'we are building a composable enterprise.' Six months in, integration complexity has tripled. What went wrong and how do you fix it?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes

- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [Digital Twin] [EA Tooling] [Decision Support]

What is a Digital Twin of the Organisation (DTO) and how does it change the role of enterprise architecture?

HINTS

- *Live EA model vs. static diagrams*
- *Simulation and scenario analysis*
- *Real-time inventory*
- *Architecture as management infrastructure*

MODEL ANSWER

A Digital Twin of the Organisation is a continuously updated, computable model of the enterprise — its systems, capabilities, data flows, costs, risks, and dependencies — that enables real-time scenario analysis and decision support.

How it differs from traditional EA:

- Traditional EA: static diagrams and documents, updated quarterly, used for planning
- DTO: live model fed by automated discovery, used for daily operational decisions

What a DTO enables:

1. Impact analysis: 'If we decommission System X, what is the blast radius?' — answered in seconds from the live graph, not weeks of manual analysis
2. Cost simulation: 'If we migrate these 50 applications to cloud, what is the cost delta?' — computed from the cost model embedded in the DTO
3. Risk visualisation: 'Which systems have a single-cloud dependency that creates a concentration risk under DORA?' — queried directly
4. AI shadow IT detection: DTO can detect when new AI tools appear in the estate that were not architecturally approved

Building a DTO:

- Automated discovery: cloud APIs, CMDBs, network scanners, code repository analysis feed the DTO continuously
- Graph model: represent systems, people, processes, data, and technology as a property graph
- Cost and risk overlays: financial data and risk assessments layered onto the architectural graph
- Tooling: Ardoq, LeanIX, Bizzdesign Horizon, or custom graph database (Neo4j) as the DTO platform

The EA role shift: from architect-as-documenter to architect-as-intelligence-provider. The CFO asks 'what would happen if we cut IT spend by 15%?' — the DTO answers.

FOLLOW-UP CHALLENGE

Your DTO discovers 847 undocumented shadow AI tools deployed by business units without architectural oversight. What is your governance response?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs

- Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D5

TECHNOLOGY SUPPLY CHAIN SECURITY

■ **INDUSTRY SIGNAL:** Supply chain attacks are the #1 fastest-growing attack vector. DORA requires ICT third-party risk management. NIS2 mandates supply chain security controls. SolarWinds, XZ Utils, and MOVEit attacks have changed the threat model permanently.

[SBOM Architecture] [Third-Party Risk] [Open Source Governance] [Model Supply Chain]

Q1 **DISTINGUISHED** [Supply Chain] [SBOM] [Third-Party Risk] [DORA]

Design a technology supply chain security architecture for an enterprise with 4,000 applications, 50,000 open-source dependencies, and 200 critical SaaS vendors.

HINTS

- SBOM generation and management
- Dependency vulnerability scanning
- Vendor risk tiering
- DORA ICT concentration risk
- Model/AI supply chain

MODEL ANSWER

The supply chain IS the attack surface. The SolarWinds, XZ Utils, and MOVEit attacks demonstrated that trusted vendors are the most effective attack vector.

Three supply chain domains to govern:

1. Software Supply Chain (50K open-source dependencies):

- SBOM (Software Bill of Materials): every application generates an SBOM at build time (SPDX or CycloneDX format)
- SBOM registry: centralised, queryable inventory of all dependencies across all applications
- Continuous vulnerability scanning: SBOM fed to vulnerability intelligence (OSV, NVD, GitHub Advisory) — alert on new CVEs matching your dependency graph
- Policy: critical vulnerabilities (CVSS ≥ 9.0) must be remediated within 72 hours. High (7.0-8.9) within 30 days.
- Signed artifacts: all build artifacts signed with Sigstore/cosign — verify provenance before deployment
- Dependency pinning: all dependencies pinned to exact versions with hash verification — no floating ranges in production

2. SaaS/ICT Vendor Supply Chain (200 critical vendors):

- Vendor risk tiering: Tier 1 (critical — bank cannot operate without), Tier 2 (important), Tier 3 (standard)
- DORA requirements for Tier 1: contractual audit rights, incident reporting SLAs, resilience testing, exit plan
- Concentration risk register: if $>X\%$ of critical processes depend on a single vendor, flag as DORA concentration risk
- Continuous monitoring: vendor security posture assessed quarterly via third-party risk platforms (BitSight, SecurityScorecard)
- Sub-outsourcing visibility: Tier 1 vendors must disclose their own critical sub-processors

3. AI Model Supply Chain:

- Model provenance: every model in the registry has documented provenance — who trained it, on what data, when
- Model signing: cryptographically signed model weights verify integrity before loading

- Training data auditing: for internally fine-tuned models, document training data lineage
- Supply chain attack vectors: compromised model weights, poisoned fine-tuning datasets, malicious LoRA adapters — each requires distinct controls

FOLLOW-UP CHALLENGE

A critical open-source library you depend on in 800 applications is found to have a backdoor (similar to XZ Utils). You have 24 hours before it becomes public. Walk through your response.

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [SBOM] [Open Source] [Governance]

Design an open-source governance programme that enables developer freedom while managing licence compliance and security risk.

HINTS

- FOSSA/Black Duck
- Approved dependency list
- Licence risk tiers
- Contribution policy

MODEL ANSWER

Open-source is the foundation of modern software. Banning it is not an option. Governing it is non-negotiable.

Licence risk tiers:

- Green (permissive): MIT, Apache 2.0, BSD — use freely with attribution
- Amber (weak copyleft): LGPL — use is fine; modifications to the library itself require sharing
- Red (strong copyleft): GPL, AGPL — legal review required before use; can force copyleft on your proprietary code
- Black (prohibited): SSPL, Commons Clause — incompatible with commercial distribution

Governance architecture:

1. SCA (Software Composition Analysis) embedded in CI/CD: FOSSA, Snyk, or Black Duck scans every dependency on every commit
2. Approved dependency catalogue: curated list of approved libraries — developers consume from the catalogue by default
3. New dependency workflow: adding a new dependency requires SCA scan + licence review. Amber/Red requires legal approval.
4. Automated SBOM generation: every build produces an SBOM in CycloneDX format, stored in artefact registry
5. Contribution policy: clear policy for when employees contribute to open-source — IP assignment, export control checks

Security controls:

- Dependency pinning with hash verification (lock files)

- Private mirror of approved packages (JFrog Artifactory / Nexus) — reduces supply chain risk from compromised public registries
- Dependency freshness policy: dependencies >2 major versions behind flagged for review

FOLLOW-UP CHALLENGE

A developer has already shipped code to production using a GPL-licensed library in your proprietary banking application. Describe your remediation.

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D6

SUSTAINABLE ARCHITECTURE & GREEN IT

■ **INDUSTRY SIGNAL:** CSRD (Corporate Sustainability Reporting Directive) mandates technology carbon reporting from 2025. Cloud providers are the #1 enterprise carbon source. Scope 3 emissions now include software supply chain. EA is uniquely positioned to measure and reduce technology carbon footprint.

[Carbon-Aware Architecture] [Green Cloud Strategy] [CSRD Technology Reporting] [Sustainable AI]

Q1 **CHIEF ARCHITECT** [Sustainable Architecture] [CSRD] [Green Cloud] [Carbon]

How should an enterprise architect integrate sustainability and carbon reduction into their architecture practice? What is the architect's role in CSRD compliance?

HINTS

- Carbon-aware scheduling
- Green cloud region selection
- Energy-efficient architecture patterns
- CSRD Scope 3 technology emissions

MODEL ANSWER

CSRD is not just a reporting requirement — it is an architecture requirement. The architect must know how technology choices affect carbon emissions.

Where technology emissions live:

- Scope 1: on-premises data centre energy (direct)
- Scope 2: purchased electricity for cloud and offices
- Scope 3: emissions from software supply chain, employee devices, and downstream use of products

Carbon-Aware Architecture Patterns:

1. Carbon-Aware Scheduling:

- Batch workloads (ML training, ETL, report generation) scheduled to run when grid carbon intensity is lowest
- Carbon-aware SDK (Microsoft open-source) provides real-time grid intensity data per cloud region
- Example: ML training jobs shifted to night hours when renewable energy percentage is highest

2. Green Cloud Region Selection:

- Cloud region carbon intensity varies significantly: Nordic regions (near-zero hydro/wind) vs. APAC coal-heavy regions
- For non-latency-sensitive workloads, prefer green regions: AWS eu-north-1 (Sweden), Azure northeurope (Ireland, 96% renewable)
- Include carbon cost in cloud placement decisions alongside financial cost

3. Efficient Architecture Patterns:

- Right-size infrastructure: over-provisioned servers waste energy. Implement auto-scaling aggressively.
- Serverless for intermittent workloads: Lambda/Functions scale to zero — no idle energy consumption
- Efficient AI: smaller, distilled models for latency-insensitive use cases consume 10-100x less energy than frontier models

4. CSRD Technology Carbon Reporting:

- Build a Technology Carbon Inventory: map applications to infrastructure, infrastructure to cloud regions, regions to carbon intensity factors

- Cloud provider carbon data: AWS Customer Carbon Footprint Tool, Azure Emissions Impact Dashboard, GCP Carbon Footprint
- Publish carbon per application — creates accountability at product P&L; level
- Report annually in CSRD format: Scope 1, 2, 3 technology emissions with year-on-year trajectory

FOLLOW-UP CHALLENGE

Your AI training programme is growing 300% year-on-year. The CSO asks you to include AI carbon impact in the CSRD report. How do you instrument and report this?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D7

ENTERPRISE INTEGRATION MODERNISATION

■ **INDUSTRY SIGNAL:** *Legacy integration debt is blocking AI adoption. 10,000-integration estates are common. Event-driven architecture is the enabler for real-time AI, composability, and open banking. MuleSoft, Kafka, and API economy are reshaping integration strategy.*

[API Economy] [Event-Driven Architecture] [Integration Modernisation] [AsyncAPI / CloudEvents]

Q1 **DISTINGUISHED** [Integration] [EDA] [API Economy] [Modernisation]

Design a strategy to modernise 10,000 enterprise integrations from point-to-point and ESB patterns to an event-driven, API-first architecture.

HINTS

- *Integration topology anti-patterns*
- *Event streaming platform*
- *API gateway strategy*
- *Strangler pattern for integrations*
- *AsyncAPI governance*

MODEL ANSWER

10,000 integrations is not primarily a technology problem — it is a governance and organisational problem. Each integration represents a coupling decision someone made. You cannot automate your way out of 10,000 coupling decisions.

Diagnostic first — classify integrations:

- Request-response (sync): replace with REST/GraphQL APIs
- Batch file transfers: replace with event streaming or API polling
- Point-to-point data sync: replace with CDC (Change Data Capture) into event stream
- ESB mediation: decompose to API gateway + lightweight event bus
- Dead integrations: 20-30% of integration estate is typically unused — decommission first

Target Architecture:

- Event Streaming Platform (Kafka/Confluent): asynchronous integration backbone
- API Gateway (Kong/Apigee): synchronous API management, rate limiting, auth, observability
- Event Mesh: multi-cluster event routing across clouds and regions (Solace or Kafka MirrorMaker)
- AsyncAPI for event contracts: standardise event schemas; version-controlled in schema registry
- CloudEvents standard: all events conform to CloudEvents spec — portability across event brokers

Migration Strategy:

Phase 1: Freeze new P2P integrations. All new integrations must use API-first or event-driven patterns.

Phase 2: High-value modernisation — top 500 integrations by business criticality converted to event streams or APIs

Phase 3: Legacy strangler — route legacy ESB traffic through event bridge; decommission ESB nodes as traffic migrates

Governance:

- API product catalogue: every API registered with owner, SLA, consumer list
- Event catalogue: every event schema documented with producer, consumers, retention policy
- Deprecation policy: 12-month notice before decommissioning any integration

FOLLOW-UP CHALLENGE

A business unit has built 400 direct database-to-database integrations to circumvent the integration platform. How do you address this?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 PRINCIPAL [API Economy] [Monetisation] [Open Banking]

How do you architect an API economy strategy for a bank that needs to support open banking (PSD2/CDR), partner APIs, and internal developer consumption from a single platform?

HINTS

- API tiers
- Developer portal
- Monetisation models
- Security by API tier
- Rate limiting differentiation

MODEL ANSWER

API economy architecture requires tiering APIs by audience and purpose.

Three API tiers:

- Tier 1: Regulatory APIs (PSD2, CDR, FDX) — mandated, standardised, open to licensed third parties
- Tier 2: Partner APIs — commercial, curated, available to vetted business partners under contract
- Tier 3: Internal APIs — available to internal developers via IDP/service catalogue

Architecture:

- API Gateway: Kong/Apigee as unified entry point. Policy enforcement varies by tier.
- Developer Portal (Backstage or Apigee portal): self-service API discovery for all three tiers
- Regulatory tier: public portal, mandatory OAuth2/OIDC (PSD2 requires eIDAS-compliant certs), 99.9% SLA, monitored by regulator
- Partner tier: contract-gated access, API key + OAuth2, tiered rate limits per contract tier, monetisation via API product catalogue
- Internal tier: OIDC service accounts, no public routing, higher rate limits, internal SLA

Monetisation model:

- Freemium: 1,000 calls/month free for startups. Converts to paid above threshold.
- Tiered pricing: Bronze/Silver/Gold tiers with rate limits and SLAs
- Revenue share: fintech partners pay per-transaction fee on business generated via the API

Security differentiation by tier:

- Regulatory: mTLS required, eIDAS certificate validation, rate limiting, PSD2-compliant consent flow
- Partner: API key + OAuth2, IP allowlisting, DDoS protection, WAF
- Internal: OIDC token, network segmentation, no external routing

FOLLOW-UP CHALLENGE

A fintech partner claims your API response times are violating the PSD2 90-second SLA. How does your architecture detect, diagnose, and remediate this?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D8

RESILIENCE ENGINEERING & DORA COMPLIANCE

■ **INDUSTRY SIGNAL:** DORA (EU Digital Operational Resilience Act) is in force for EU financial institutions in 2025. It mandates operational resilience testing, ICT vendor risk management, and incident classification. It is the most prescriptive technology regulation in financial services history.

[DORA Architecture Requirements] [Resilience Testing] [ICT Incident Classification] [Critical Functions]

Q1 **DISTINGUISHED** [DORA] [Operational Resilience] [Architecture]

Design an architecture programme to achieve and maintain DORA compliance for a EU-regulated financial institution.

HINTS

- Critical function identification
- ICT risk management framework
- TLPT testing
- Concentration risk
- Incident reporting 4-hour SLA

MODEL ANSWER

DORA is not a security framework — it is an operational resilience framework. The distinction matters: the regulator cares whether you can continue to operate through disruption, not just whether you have controls in place.

DORA Architecture Requirements:

1. Critical Function Mapping:

- Identify and document all critical or important functions (CIF): the business processes that, if disrupted, would materially impact financial stability or customer harm
- Map CIFs to supporting ICT systems, internal processes, and third-party providers
- This mapping is the foundation of all DORA compliance work — regulators examine it directly

2. ICT Risk Management Framework:

- Maintain a live ICT asset register linked to CIF mapping
- Identify, classify, and treat ICT risks continuously — not annually
- Board-level ICT risk reporting: DORA requires management body accountability for ICT risk

3. ICT Third-Party Risk Management:

- Register of all ICT third-party providers with CIF dependency mapping
- Tier 1 vendors (CIF-supporting): mandatory contractual requirements — audit rights, incident notification, exit plan, sub-outsourcing disclosure
- Concentration risk: flag dependencies where >X% of CIFs depend on a single provider or a single cloud region
- Annual ICT vendor risk assessments with evidence

4. Operational Resilience Testing:

- Annual resilience testing programme for all CIF-supporting systems
- TLPT (Threat-Led Penetration Testing): every 3 years for significant institutions — red team simulation of real threats
- Test results documented and remediation plans tracked to closure

5. ICT Incident Management:

- Classify incidents by DORA criteria: impact on CIFs, duration, geographic spread, data losses, reputational impact
- Major incidents reported to regulator: initial notification within 4 hours, intermediate report within 72 hours, final report within 1 month
- Automated incident triage tool that assesses DORA classification in real-time during incident response

FOLLOW-UP CHALLENGE

During a DORA examination, the regulator finds that your CIF mapping excludes 3 systems that support critical payment processing. What is your immediate response and how do you remediate?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [Chaos Engineering] [Resilience Testing] [SRE]

Design a continuous resilience testing programme that satisfies DORA testing requirements while embedding resilience culture in engineering teams.

HINTS

- *Chaos engineering maturity model*
- *GameDays*
- *TLPT scope*
- *Automated vs. manual testing*

MODEL ANSWER

DORA requires testing. But testing just for DORA produces theatrical compliance. Resilience culture produces actual resilience.

Four levels of resilience testing:

Level 1 — Automated Unit Tests (continuous):

- Chaos engineering in CI/CD: LitmusChaos or AWS FIS inject faults in non-production automatically
- Fitness functions: automated checks for resilience patterns (circuit breakers configured, retry policies present, timeouts defined)

Level 2 — Chaos Experiments (monthly):

- Defined chaos experiments run against production-like staging: pod failures, network partitions, dependency latency
- Hypothesis-driven: 'When dependency X has 5-second latency, our P99 response time will remain under 10 seconds'
- Results reviewed in monthly resilience review

Level 3 — GameDays (quarterly):

- Full team exercise: realistic failure scenarios injected into production (with safeguards)
- Measures: time to detect, time to diagnose, time to recover, runbook quality
- Scenarios aligned to DORA critical function risk register: cloud region outage, vendor failure, data corruption

Level 4 — TLPT (every 3 years for significant institutions):

- Threat-Led Penetration Testing conducted by approved external red team
- Scope includes: cyber attacks, social engineering, physical attacks on critical infrastructure
- Results shared with regulator under TIBER-EU/DORA framework

Culture embedding:

- Resilience score per service: publicly visible in developer portal
- Blameless post-mortems mandatory after every incident
- Error budget policy: teams with low resilience scores cannot ship new features until resilience improves

FOLLOW-UP CHALLENGE

Engineering teams are refusing to participate in GameDays because they disrupt sprint commitments. How do you resolve this?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D9

AUTONOMOUS OPERATIONS & AIOPS

■ **INDUSTRY SIGNAL:** By 2026, G2000 companies will deploy thousands of AI agents. AIOps is moving from anomaly detection to autonomous remediation. The architecture of autonomous operations — where AI manages infrastructure — is an emerging discipline with no established playbook.

[Autonomous Operations Platform] [AIOps Architecture] [Self-Healing Systems] [Human Override Governance]

Q1 **DISTINGUISHED** [Autonomous Operations] [AIOps] [Self-Healing] [Architecture]

Design an autonomous operations platform for a financial institution where AI agents can detect, diagnose, and remediate production incidents without human intervention — within safety boundaries.

HINTS

- Tiered autonomy
- Blast radius constraints
- Human override
- Audit trail
- Runbook automation

MODEL ANSWER

Autonomous operations is not about removing humans — it is about removing humans from the toil of repetitive, well-understood remediation, so they can focus on novel and high-stakes situations.

Architecture:

1. Observability Foundation:

- Unified observability: metrics, logs, traces, and events in a single data plane (OpenTelemetry → Grafana Stack or Datadog)
- Topology-aware monitoring: understand how systems depend on each other — alert routing uses dependency graph
- ML-based anomaly detection: baseline normal behaviour, detect deviations without static thresholds

2. Incident Intelligence Layer:

- AI triage: inbound alerts classified by: severity, affected system, impacted CIF, likely root cause category
- Similar incident retrieval: vector search over incident history to find comparable past incidents and their solutions
- Automated root cause hypothesis: AI generates top-3 probable root causes with evidence from telemetry

3. Autonomous Remediation — Tiered Autonomy:

- Tier A (fully autonomous): known runbook, reversible action, low blast radius — AI executes immediately

Examples: pod restart, cache flush, connection pool reset, feature flag toggle

- Tier B (autonomous with notification): known runbook, reversible, medium blast radius — AI executes, human notified

Examples: auto-scaling trigger, circuit breaker activation, traffic shift to healthy instance

- Tier C (human approval required): irreversible, high blast radius, or novel scenario

Examples: database failover, payment system switch, network routing change

4. Governance and Safety:

- Every autonomous action: logged with full reasoning trace, evidence used, action taken, outcome
- Human override: any action can be reversed by on-call engineer within grace period
- Blast radius limits: autonomous agent cannot affect more than N instances or X% of traffic without human approval
- Kill switch: disable all autonomous remediation globally in under 60 seconds
- Weekly review: all autonomous actions reviewed — actions incorrectly taken or not taken improve the model

FOLLOW-UP CHALLENGE

An autonomous remediation agent correctly detects a production issue but applies the wrong fix, causing a cascade failure. Walk through your incident response and architectural remediation.

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

ARCHITECTURE FOR AI REGULATION & RESPONSIBLE AI

■ **INDUSTRY SIGNAL:** 92% of EA leaders cite AI and agentic architecture as their top 2026 priority. Responsible AI is moving from ethics committee to hard regulatory requirement. Explainability, fairness auditing, and bias monitoring are becoming architectural obligations.

[Responsible AI Framework] [Explainability Architecture] [Fairness Monitoring] [AI Incident Response]

Q1 **DISTINGUISHED** [Responsible AI] [Explainability] [Fairness] [Regulatory]

Design a Responsible AI architecture that makes explainability, fairness monitoring, and bias detection operational — not just policy documents.

HINTS

- SHAP/LIME for explainability
- Disparate impact monitoring
- Fairness metrics by model type
- Regulatory examination readiness

MODEL ANSWER

Responsible AI fails when it is only a policy. It succeeds when explainability and fairness are measured continuously as operational metrics, the same way availability and latency are.

Explainability Architecture:

- Global explanations: SHAP feature importance generated at model training, stored in model registry. Shows which features drive model behaviour overall.
- Local explanations: for every consequential decision (credit denial, fraud flag, HR screening), a per-decision explanation generated and stored. LIME or SHAP for tabular models.
- LLM decisions: chain-of-thought logging captures the model's reasoning. Stored in audit log. Searchable by case ID.
- Customer-facing explanation: natural language explanation generated from technical explanation — 'Your credit application was declined primarily due to...' Legal review of explanation templates.

Fairness Monitoring:

- Define protected attributes for each model: race (proxy), gender, age, postcode (as socioeconomic proxy)
- Fairness metrics tracked continuously: Demographic Parity Ratio, Equal Opportunity Difference, Predictive Parity
- Alert thresholds: if demographic parity ratio deviates >5% from baseline, automatic alert to Model Risk team
- Disaggregated performance reporting: model accuracy/precision/recall reported by demographic cohort, not just overall

Bias Detection:

- Pre-deployment: bias assessment in model validation pipeline — mandatory for Tier 3+ models
- Post-deployment: continuous monitoring — rolling 30-day fairness metrics computed daily
- Adverse impact analysis: if model decisions have statistically significant adverse impact on protected group (4/5ths rule), immediate escalation

Regulatory Examination Readiness:

- Model inventory: every production model catalogued with: risk tier, validation date, fairness metrics, explainability method

- Decision audit trail: regulators can query any AI decision by case ID and receive: input data, model version, decision, explanation, human override (if any)
- Fairness dashboard: real-time visibility into fairness metrics across all production models

FOLLOW-UP CHALLENGE

Your credit model's fairness monitoring shows a sudden 8% adverse impact on a protected demographic cohort. The model hasn't changed. Walk through your investigation.

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **PRINCIPAL** [AI Incident Response] [Model Failure] [Governance]

Design an AI incident response framework. How is responding to an AI model failure different from a traditional system outage?

HINTS

- *Non-determinism*
- *Model drift vs. code bug*
- *Reputational risk*
- *Regulatory notification*
- *Rollback vs. retrain*

MODEL ANSWER

AI incidents are categorically different from software incidents because the failure mode is probabilistic, not binary. A model does not crash — it degrades. Detecting gradual quality degradation is harder than detecting a 500 error rate.

AI-specific incident categories:

1. Performance degradation: model accuracy/quality drops without any code change (data drift, distribution shift)
2. Fairness incident: model begins producing discriminatory outputs — may be legal and regulatory incident
3. Hallucination incident: LLM produces confident but factually incorrect outputs with material impact (wrong compliance advice, incorrect financial data)
4. Adversarial attack: model manipulated via prompt injection, adversarial inputs, or data poisoning
5. Capability incident: model used outside its validated scope — fine-tuned for X, deployed for Y

AI Incident Response Playbook:

1. Detect: automated quality SLO monitoring triggers alert. Human review of flagged outputs.
2. Assess: is this a model issue or a data issue? Pull input distribution analysis. Compare with training distribution.
3. Contain: for material failures, implement circuit breaker — route to fallback model or human review queue
4. Investigate: model card review, feature drift analysis, recent training data changes, deployment changelog
5. Remediate: options in priority order: rollback to previous model version, retrain on updated data, fine-tune on corrected examples, decommission and replace

6. Notify: if fairness or regulatory incident, notify Model Risk Committee, Legal, and Compliance immediately.
EU AI Act: incidents reported to EU AI Office for high-risk systems.

7. Post-incident: model post-mortem (different from software post-mortem — includes training data analysis, evaluation gap analysis)

FOLLOW-UP CHALLENGE

Your LLM-based financial advice system gives incorrect tax guidance to 50,000 customers. Some have already filed tax returns based on it. What is your response in the first 48 hours?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

SECTION D11

EDGE COMPUTING & DISTRIBUTED ARCHITECTURE

■ **INDUSTRY SIGNAL:** By 2026, edge computing handles 75% of enterprise-generated data. 5G, IoT, and AI inference at the edge create new architectural requirements. Financial services, retail, and manufacturing are deploying intelligence at the edge.

[Edge Architecture Patterns] [Edge AI] [5G Enterprise Architecture] [Edge Security]

Q1 **PRINCIPAL** [Edge Computing] [Edge AI] [Distributed Architecture]

Design an edge computing architecture for a retail bank that needs real-time fraud detection at 5,000 branch locations without cloud dependency.

HINTS

- Edge node specifications
- Model deployment at edge
- Data sync strategy
- Connectivity resilience
- Update management

MODEL ANSWER

Edge fraud detection requires sub-100ms decisioning. Cloud round-trip latency for 5,000 branches globally is unacceptable for point-of-sale fraud prevention.

Architecture:

1. Edge Node Design:

- Ruggedised edge compute per branch cluster (AWS Outposts Local Zones, Azure Stack Edge, or custom x86 appliance)
- Local model inference: quantised fraud detection model (INT8) running on edge GPU/NPU
- Local cache: recent transaction history for the branch, local feature store for real-time feature computation
- Local decision store: audit log of all fraud decisions, synced to cloud when connectivity available

2. Model Management at Edge:

- Central model registry: source of truth for approved model versions
- OTA (Over-the-Air) update: new model versions pushed to edge during low-traffic windows
- Gradual rollout: canary deployment — new model version deployed to 1% of branches first, monitored for 24h before wider rollout
- Rollback: previous model version retained on edge node for immediate rollback if anomaly detected

3. Connectivity Resilience:

- Edge operates independently when cloud connectivity lost — local model, local decision
- Degraded mode: if local feature store is stale (>4h), apply more conservative fraud thresholds
- Event streaming sync: when connectivity restored, transaction events streamed to cloud for global model retraining

4. Edge Security:

- Hardware security module (HSM) in each edge node for model signing key and local encryption key
- Secure boot: edge node verifies firmware and model integrity on startup
- Network: edge nodes communicate via private WAN, not public internet. Zero Trust enforced — each node has SPIFFE identity.

FOLLOW-UP CHALLENGE

Your edge fraud model has been running for 6 months. You discover its false positive rate is 3x higher for transactions from a specific region. How do you investigate and remediate without taking the edge nodes offline?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

ARCHITECTURE LEADERSHIP & THE AUGMENTED ARCHITECT

■ **INDUSTRY SIGNAL:** Forrester's 'Augmented Architect' (2025): architects who combine AI fluency with business acumen will lead. 72% of EA professionals cite data and AI skills as their top priority. Behavioural science is entering EA practice. The EA function is evolving toward Internal Management Consultancy.

[EA Value Proposition 2026] [AI-Augmented Architecture Practice] [Architecture as Consultancy] [Skills for Distinguished Architects]

Q1 **DISTINGUISHED** [EA Leadership] [Value Proposition] [Augmented Architect]

The EA function is under pressure to prove its value. What is the EA value proposition in 2026, and how has the architect's role changed with AI?

HINTS

- From documenter to strategist
- AI as architectural amplifier
- Internal management consultancy
- Board-level relevance

MODEL ANSWER

The traditional EA value proposition — 'we document the current state and produce architecture diagrams' — is dead. AI can generate architecture diagrams. AI can query the IT estate. AI can produce capability maps.

The new EA value proposition has three components:

1. Strategic Intelligence Provider:

- CEOs want growth. 62% rank it as their top priority (Gartner 2025). They need someone who can see across organisational silos and identify where technology can create or protect competitive advantage.
- The architect's unique value: end-to-end view of the enterprise that no other function has. The CFO sees cost. The CTO sees systems. The business sees their domain. The architect sees how they all connect.
- Deliver strategic insights to senior management — not just architecture artefacts. 47% of EA leaders say this is their top priority (Gartner 2025).

2. AI Governance and Enablement:

- 80% of CEOs expect AI to contribute to top-line growth. Only 3% of CIOs expect the same (2026 data). This gap is not a communication problem — it is an execution architecture problem.
- The architect bridges this gap: translates AI ambition into architecture patterns, governance frameworks, and platform investments that actually deliver.
- AI shadow IT is exploding — business units deploying AI tools without governance. Only the EA function has the cross-cutting visibility to manage this.

3. Risk and Complexity Manager:

- DORA, EU AI Act, PQC migration, supply chain security — each is an architectural challenge that crosses every business domain
- The architect is the only function that can provide the board with a coherent view of technology risk

The Augmented Architect:

- Uses AI to accelerate documentation, discovery, and analysis — freeing time for the work only humans can do: judgement, trust-building, political navigation, creative problem-solving
- Develops business and financial acumen alongside technical depth — can stand in the CFO's office and justify investments in financial terms

- Behavioural science literacy: understands why governance fails, why teams resist change, how to design systems that get adopted

FOLLOW-UP CHALLENGE

The CEO asks you directly: 'What would happen to this company if we eliminated the EA function?' How do you answer honestly?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
- Architecture principles and tradeoffs
- Security and compliance implications
- Operational and reliability considerations
- Financial impact and platform economics
- Governance, risk and regulatory controls
- Alternative approaches and decision rationale

Q2 **CHIEF ARCHITECT** [AI-Augmented EA] [Tooling] [Productivity]

How do you use AI to augment your architecture practice without losing the quality of judgement that makes a senior architect valuable?

HINTS

- AI for acceleration not replacement
- LLM for documentation
- Automated discovery
- Scenario simulation
- Where AI fails in architecture

MODEL ANSWER

AI augments architects in three dimensions — acceleration, breadth, and simulation — but it cannot replace the three things that make a Distinguished Architect valuable: judgement, trust, and political intelligence.

Where AI genuinely accelerates architecture work:

1. Documentation: generate first drafts of ADRs, architecture documents, and API specifications from meeting notes and design discussions. An architect who previously spent 30% of time documenting now spends 10%.
2. Discovery: AI can query the IT estate, summarise the DTO, identify patterns across 4,000 applications. Replaces weeks of manual inventory analysis.
3. Impact analysis: 'What are the downstream effects of decommissioning this system?' AI traverses the dependency graph and generates an impact report in seconds.
4. Standards checking: AI reviews architecture proposals against reference architecture standards — catches deviations automatically.
5. Scenario generation: AI generates alternative architecture options for a given problem, broadening the solution space.

Where AI fails in architecture (the human-only space):

- Organisational politics: knowing which stakeholder will block a decision and why. AI cannot read a room.
- Tradeoff judgement under uncertainty: when data is incomplete, the architect makes a judgement call informed by experience. AI averages the past.
- Building trust: a board will not bet the company on an AI recommendation. They trust the architect who has earned credibility.
- First-principles reasoning: genuinely novel problems require thinking from first principles, not pattern-matching from training data.

The risk: architects who over-delegate to AI produce average-quality architecture at high speed. The value is in being able to identify where the AI is wrong — which requires deep expertise.

FOLLOW-UP CHALLENGE

A junior architect on your team is producing 10x more architecture documents than their peers because they are using AI extensively. The quality is average. How do you coach them?

EXPECTED DISCUSSION AREAS

- Business drivers and outcomes
 - Architecture principles and tradeoffs
 - Security and compliance implications
 - Operational and reliability considerations
 - Financial impact and platform economics
 - Governance, risk and regulatory controls
 - Alternative approaches and decision rationale
-

CROSS-REFERENCE: VOLUME 1 + DELTA

Topic	Volume 1	Delta Addition
AI Governance	AI Operating Model, SR 11-7	EU AI Act, Responsible AI, AI Incidents
Security Architecture	Zero Trust, PAM, Secrets	PQC Migration, Supply Chain Security
Cloud Strategy	Multi-cloud, Landing Zones	DORA Compliance, Edge Computing
Identity Architecture	OAuth2, ABAC, Agent Identity	PQC impact on JWT/SAML/PKI
Data Architecture	Data Mesh, 100 PB, Metadata	AI FinOps data costs, CSRD reporting
Platform Engineering	IDP, Build vs Buy	Composable Architecture, Digital Twin
Integration	API-first, Event-driven (mentioned)	Full integration modernisation strategy
Reliability	SLOs, Outage Recovery	DORA Testing, Chaos Engineering, AIOps
AI Architecture	AI Platform, LLM Gateway	Responsible AI, AI FinOps, Autonomous Ops
Agentic Systems	Agent Identity, Memory, HITL	AI FinOps for agents, EU AI Act agents
EA Practice	TOGAF, ARB, Governance	Augmented Architect, DTO, EA value 2026
Sustainability	Not covered	CSRD, Carbon-Aware Architecture, Green IT

INTERVIEW PREPARATION GUIDE — HOW TO USE BOTH VOLUMES

Interview Type	Volume 1 Priority	Delta Priority
FAANG / Big Tech (Architect)	All sections, emphasis S01-S05	D4 Composable, D9 AIOps, D12 Leadership
Financial Services (EA/Principal)	S04 Security, S05 Identity, S12 Banking	D1 PQC, D2 EU AI Act, D8 DORA
CTO / Chief Architect	S03 Exec Comms, S14 Distinguished	D2, D3 FinOps, D10 Responsible AI, D12
Cloud/Platform Architect	S07 Platform, S08 Cloud	D5 Supply Chain, D6 Sustainability, D11 Edge
AI Architect / CAIO	S09 AI, S10 Agentic	D2 EU AI Act, D3 FinOps, D9 AIOps, D10
Security Architect / CISO	S04 Security, S05 Identity	D1 PQC, D5 Supply Chain, D8 DORA
Data Architect / CDO	S06 Data Architecture	D3 AI FinOps, D6 CSRD, D7 Integration

EA INTERVIEW HANDBOOK — DELTA EDITION

Emerging Topics for 2025-2026

12 new sections · 26 new questions · Industry-verified 2025-2026 content
Use alongside Volume 1 for complete Distinguished Architect interview preparation